
Guía Completa de Resolución

OWASP Juice Shop

Manual de Soluciones para todos los desafíos

Seguridad Aplicada a Sistemas de Información

Facultad de Informática y Diseño

Docente: Ing. Rodrigo Atilio Elgueta

Ciclo Académico Vigente

Índice

1. Cómo usar esta guía	3
1.1. Convenciones	3
2. Configuración del Entorno	3
2.1. Opción recomendada: Docker	3
2.2. Opción con Node.js	3
2.3. Verificar que funciona	4
2.4. Herramientas necesarias	4
3. El Score Board y la mecánica de desafíos	4
4. Tabla Maestra de Desafíos	4
5. Categoría: Injection	6
6. Categoría: Cross-Site Scripting (XSS)	9
7. Categoría: Broken Access Control	11
8. Categoría: Broken Authentication	12
9. Categoría: Sensitive Data Exposure	15
10. Categoría: XXE (XML External Entities)	17
11. Categoría: Security Misconfiguration	18
12. Categoría: Business Logic	19
13. Categoría: Improper Input Validation	20

14.Categoría: Insecure Deserialization	20
15.Categoría: Cryptographic Issues	21
16.Categoría: Documentation / Awareness	21
17.Metodología de Trabajo Recomendada	21
17.1. Checklist del Hacker Web	21
18.Cheatsheet de Comandos Útiles	22
19.Fuentes y bibliografía	22
19.1. Documentación oficial y libro de soluciones	22
19.2. Bibliografía de la cátedra	22
19.3. Herramientas	23

1. Cómo usar esta guía

Recomendación pedagógica

Esta guía contiene las **soluciones** de los desafíos. Se recomienda:

1. Intentar resolver el desafío **sin ayuda** durante al menos 30 minutos.
2. Si te trabás, leer primero la **Pista** (te orienta sin dar la respuesta).
3. Solo recurrir a la **Solución** completa si agotaste las opciones.
4. **Documentar** cada desafío resuelto en tu informe usando la plantilla de la cátedra.

Ética y Legalidad

Estas técnicas **solo** pueden aplicarse contra la instancia local de Juice Shop que vos mismo levantaste. Usarlas contra otros sistemas sin autorización constituye un delito.

1.1. Convenciones

- ★ a ★★★★★★: nivel de dificultad del desafío.
- La URL base asumida es <http://localhost:3000>.
- Los nombres, endpoints y pistas pueden cambiar entre versiones; el **Score Board de la instancia** es la fuente de verdad.
- Los ejemplos se deben probar únicamente en la instancia local y descartable del laboratorio. No se incluyen payloads de DoS ni de ejecución remota.

Control de versión

Antes de resolver la guía, anotá la versión de Juice Shop (**Help** → **About** o la etiqueta de Docker). Si un nombre o endpoint de esta guía no coincide, priorizá el desafío y la pista que muestra tu Score Board y documentá la diferencia.

2. Configuración del Entorno

2.1. Opción recomendada: Docker

```
1 docker pull bkimminich/juice-shop
2 docker run --rm -p 3000:3000 bkimminich/juice-shop
```

Accedé a <http://localhost:3000>. Para reiniciar todo (incluida la BD), simplemente eliminá el contenedor y volvé a ejecutarlo.

2.2. Opción con Node.js

```
1 git clone https://github.com/juice-shop/juice-shop.git
2 cd juice-shop
3 npm install
4 npm start
```

2.3. Verificar que funciona

- Deberías ver la tienda «OWASP Juice Shop».
- Abrió la consola del navegador (F12); no debe haber errores de conexión.
- Regístrate con un usuario de prueba (ej. `test@test.com` / `test1234`).

2.4. Herramientas necesarias

Herramienta	Uso principal
Burp Suite Community	Interceptación y modificación de peticiones HTTP/REST.
FoxyProxy (Firefox)	Alternar el tráfico a través de Burp (puerto 8080).
DevTools del navegador (F12)	Inspeccionar JS, Network, Storage, Console.
JWT.io	Decodificar y manipular tokens JWT.
cURL / HTTPie	Enviar peticiones a la API desde terminal.
SQLmap	Automatizar inyecciones SQL (uso educativo).

3. El Score Board y la mecánica de desafíos

El **Score Board** es la página oculta que lista todos los desafíos, su estado y da pistas. Encontrarlo es el primer desafío.

Score Board

Objetivo: Encontrar la página no anunciada con el tablero de puntuación.

Solución

1. Abrió las DevTools (F12) y andá a la pestaña **Sources** o **Debugger**.
2. En los archivos JS principales (`main.*.js`), presioná **Ctrl+F**.
3. Buscá la palabra **score**.
4. Encontrarás una definición de ruta de Angular: `path: 'score-board'`.
5. Navegá manualmente a <http://localhost:3000/#/score-board>.

Dato útil

En versiones recientes, si activás los «Hacking Challenges» desde el menú de configuración o encontrás el Score Board, se desbloquean pistas adicionales y un modo tutorial.

4. Tabla Maestra de Desafíos

A continuación, el listado completo organizado por categoría. Las soluciones detalladas de cada uno están en las secciones posteriores.

Desafío	Categoría	Dif.
Score Board	Misconfiguration	★
Error Handling	Misconfiguration	★
Privacy Policy	Documentation	★
Confidential Document	Sensitive Data	★
Login Admin	Injection	★
Forged Feedback	Injection	★★
Zero Stars	Validation	★
Client-side XSS Protection	XSS	★
CAPTCHA Bypass	Auth	★★★★
Exposed Metrics	Sensitive Data	★
Password Strength	Auth	★★
Repetitive Registration	Auth	★
Easter Egg	Sensitive Data	★★
Forged Review	Business Logic	★★
Product Tampering	Injection	★★★★
Basket Access	Access Control	★★
Manipulate Basket	Access Control	★★
User Credentials	Auth	★★
Admin Registration	Access Control	★★
Security Answer	Auth	★★
Login Jim	Injection	★★
Login Bender	Injection	★★
Login Amy	Auth	★★★★
Login MC SafeSearch	Auth	★★★★
Login Support Team	Auth	★★★★
Database Schema	Injection	★★★★
Forged Coupon	Business Logic	★★★★★
Christmas Special	Business Logic	★★
Upload Size	Validation	★★
Upload Type	Validation	★★
XXE Data Exfiltration	XXE	★★★★
XXE DoS	XXE	★★★★
Leaked Unsafe Product	Sensitive Data	★★★★
Leaked Access Logs	Sensitive Data	★★★★
Access Log	Sensitive Data	★★★★
Missing Encoding	Sensitive Data	★★
JWT Issues	Auth	★★
Forged Signed JWT	Auth	★★★★★
JWT Unsigned	Auth	★★★★
Login CISO	Auth	★★★★
Two Factor Authentication	Auth	★★★★★
Reset Jim's Password	Auth	★★★★
Reset Bender's Password	Auth	★★★★★
Reset Morty's Password	Auth	★★★★★
NoSQL DoS	Injection	★★★★★
Mass Disparition	Injection	★★★★★
DOM XSS	XSS	★
XSS (stored)	XSS	★★★★
Bonus Payload	XSS	★★★★

Desafío	Categoría	Dif.
Local File Read	XSS	★★★★★
Cross-Site Imaging	Sensitive Data	★★★★★
Blocked RCE DoS	Deserialization	★★★★★
Blocked RCE	Deserialization	★★★★★★
Weird Crypto	Crypto	★★
Forgotten Sales Backup	Sensitive Data	★★★
Deprecated Interface	Injection	★★★
Missing Security Headers	Misconfiguration	★★
CORS Misconfiguration	Misconfiguration	★★★
Payback Time	Business Logic	★★★
Coupon Issue	Business Logic	★★
Easter Egg Access	Sensitive Data	★★
Extra Language	Validation	★★
GDPR Data Erasure	Access Control	★★
GDPR Data Theft	Access Control	★★

5. Categoría: Injection

Inyección (OWASP A03)

Las fallas de inyección ocurren cuando los datos del usuario se envían al intérprete (SQL, NoSQL, OS) como parte de un comando. El atacante engaña al intérprete para ejecutar comandos no deseados. En Juice Shop hay inyecciones **SQL** (SQLite) y **NoSQL**.

Login Admin ★

Objetivo: Iniciar sesión como administrador sin conocer su contraseña.

Pista

El campo de email no sanitiza la entrada. Probá una tautología SQL.

Solución

En el campo **Email** ingresá una inyección que haga la condición siempre verdadera:

```
1 ' OR 1=1 --
```

En **Password** poné cualquier valor. La consulta resultante queda:

```
1 SELECT * FROM Users WHERE email = '' OR 1=1 --' AND password = '...'
```

Como 1=1 siempre es verdadero, devuelve al primer usuario (el admin).

Login Jim ★★

Objetivo: Iniciar sesión como Jim.

Solución

Similar al anterior, pero dirigido al usuario Jim. Usá:

```
1 jim@juice-sh.op' OR 1=1 --
```

Si conocés el email exacto, también podés usar ' para romper la consulta y comentar el resto.

Login Bender



Objetivo: Iniciar sesión como Bender.

Solución

Misma técnica dirigida a Bender:

```
1 bender@juice-sh.op' OR 1=1 --
```

Login Amy



Objetivo: Iniciar sesión como Amy.

Solución

Amy usa un email poco común. Podés resolverlo por SQLi:

```
1 amy@juice-sh.op' OR 1=1 --
```

O investigar el email correcto (a veces es `amy@juice-sh.op` o una variante). Si la inyección directa falla, combiná con UNION o fuerza bruta ligera.

Database Schema



Objetivo: Obtener el esquema completo de la base de datos.

Pista

Usá una consulta UNION SELECT para leer las tablas de `sqlite_master`.

Solución

SQLite guarda el esquema en la tabla `sqlite_master`. Inyectá un UNION que devuelva esa información. En un campo vulnerable (por ejemplo, la búsqueda de productos o el filtro):

```
1 qwert' UNION SELECT sql FROM sqlite_master --
```

Esto lista las sentencias CREATE TABLE de toda la BD, revelando el esquema.

Forged Feedback

Objetivo: Enviar un feedback haciéndote pasar por otro usuario.

Solución

1. Escribí un feedback normal y envíalo.
2. Interceptá la petición POST a `/api/Feedbacks/` con Burp.
3. Verás un JSON con un campo `UserId`. Cambialo al ID de otro usuario (ej. 1).
4. Reenviá. El feedback quedará registrado a nombre de ese usuario.

Forged Review

Objetivo: Editar un review que no te pertenece.

Solución

1. Creá un review propio en cualquier producto.
2. Con Burp, capturá el PUT a `/api/Reviews/<id>`.
3. Modificá el campo `message` y/o `author` para alterar un review ajeno.
4. Alternativamente, cambiá el `id` del review en la URL para editar el de otro usuario.

Product Tampering

Objetivo: Cambiar el precio de un producto.

Solución

1. Interceptá con Burp la actualización de un producto (PUT a `/api/Products/<id>`).
2. Modificá el campo `price` a un valor mucho menor (ej. 0.01).
3. Reenviá. Si la API no valida permisos de escritura, el precio cambia.

NoSQL DoS

Objetivo: Provocar una denegación de servicio vía consulta NoSQL costosa.

Solución

No ejecutes una prueba de agotamiento de recursos en una instancia compartida. Para documentar el desafío, identificá en el código o en el Score Board el endpoint vulnerable, describí el operador o la consulta que permite el consumo excesivo y verificá únicamente que la aplicación rechaza entradas fuera de los límites esperados. Si la práctica exige una demostración, usá un límite de tiempo y una copia descartable de la instancia, con autorización docente.

Mass Disparition

Objetivo: Eliminar todos los productos del catálogo.

Solución

Este es uno de los más difíciles. Requiere encontrar el endpoint de borrado y enviar una petición que elimine en masa (por ejemplo, un DELETE sin filtro o un comando que borre la colección). Buscá en el código JS del cliente referencias a rutas de borrado de productos y replicá la llamada con Burp, ampliando el alcance del filtro.

Deprecated Interface

Objetivo: Usar una interfaz/API obsoleta pero aún funcional.

Solución

Buscá en el código JS referencias a endpoints antiguos (a menudo relacionados con el sistema B2B o una versión previa de la API). Navegá a esa ruta oculta o envía una petición directa. Suelen estar en `/b2b` o endpoints no enlazados en la UI.

6. Categoría: Cross-Site Scripting (XSS)

XSS (OWASP A03)

El XSS permite inyectar scripts que se ejecutan en el navegador de la víctima. Tipos: **Reflejado** (en la respuesta), **Almacenado** (guardado en BD) y **DOM** (manipulación del DOM por JavaScript del cliente).

Client-side XSS Protection

Objetivo: Demostrar que el filtro XSS del cliente puede eludirse.

Solución

El filtro XSS del lado del cliente puede desactivarse o eludirse. En la búsqueda, ingresá un payload que el filtro no detecte, por ejemplo usando codificación o etiquetas alternativas:

```
1 <iframe src="javascript:alert('xss')">
```

Si el filtro bloquea `<script>`, usá `<iframe>`, `<svg onload>` o `<img onerror>`.

DOM XSS

Objetivo: Ejecutar JavaScript mediante manipulación del DOM.

Solución

En la barra de búsqueda, el término se refleja en el DOM. Inyectá:

```
1 <iframe src="javascript:alert('xss')">
```

Angular renderiza el contenido y ejecuta el script. También funciona:

```
1 <script>alert("xss")</script>
```

Zero Stars



Objetivo: Enviar un review con 0 estrellas (la UI no lo permite).

Solución

1. Escribí un review y seleccioná 1 estrella.
2. Interceptá la petición con Burp.
3. Cambiá el valor de `rating` (o `stars`) a 0.
4. Reenviá.

Bonus Payload



Objetivo: Ejecutar un payload XSS específico requerido por el desafío.

Solución

El Score Board muestra el payload exacto esperado (suele ser un `alert` con un string concreto o una llamada a una función específica). Leé el hint del desafío en el Score Board y replicá el payload indicado en el campo vulnerable (búsqueda o feedback).

Local File Read



Objetivo: Leer un archivo local del servidor a través de XSS.

Solución

Combiná un XSS con una ruta que permita leer archivos (path traversal). Un payload típico usa un `iframe` o `fetch` apuntando a un endpoint vulnerable:

```
1 <iframe src="file:///etc/passwd"></iframe>
```

O aprovechá un endpoint que sirva archivos sin validar la ruta.

7. Categoría: Broken Access Control

Control de Acceso Roto (OWASP A01)

Los usuarios pueden actuar fuera de sus permisos: ver datos ajenos, editar recursos de otros, acceder a funciones administrativas. Es la categoría #1 del OWASP Top 10.

Confidential Document

Objetivo: Acceder a un documento confidencial no público.

Solución

1. Buscá en el código JS (o en `robots.txt`) referencias a directorios ocultos. Encontrarás `/ftp`.
2. Navegá a <http://localhost:3000/ftp>.
3. Verás una lista de archivos. Los `.md` están protegidos por extensión.
4. Para descargar un archivo restringido, usá la variante exacta indicada por el Score Board. En versiones que conservan este desafío, la ruta se construye así:

```
1 http://localhost:3000/ftp/acquisitions.md%2500.md
```

5. El documento confidencial suele ser `acquisitions.md`.

Basket Access

Objetivo: Acceder al carrito de compras de otro usuario.

Solución

1. Iniciá sesión y andá a tu carrito.
2. Interceptá la petición GET. La API es del tipo `/rest/basket/1` (donde 1 es tu ID).
3. Cambiá el ID a 2, 3, etc., y reenviá.
4. El servidor no valida si sos el dueño del basket y devuelve los datos ajenos.

Manipulate Basket

Objetivo: Manipular el contenido del carrito (agregar productos sin pagar o con descuento).

Solución

Interceptá las peticiones POST/PUT al basket. Podés agregar productos con cantidad negativa o precio modificado, o cambiar el ID del producto por uno más caro sin ajustar el precio.

Admin Registration

Objetivo: Registrarte como usuario con rol de administrador.

Solución

1. Andá al formulario de registro.
2. Interceptá la petición POST a `/api/Users/` con Burp.
3. Agregá el campo `role` con valor `admin` en el JSON:

```
1 {"email":"mio@test.com","password":"...", "role":"admin"}
```
4. Reenviá. Tu usuario queda creado con privilegios de administrador.

User Credentials

Objetivo: Obtener las credenciales de un usuario.

Solución

Combiná técnicas de información: revisá respuestas de la API que filtren datos, o explotá el login con SQLi para extraer el hash/contraseña. También podés encontrar credenciales en archivos de respaldo expuestos (ver *Confidential Document*).

GDPR Data Erasure / Theft

Objetivo: Acceder o manipular datos personales invocando el endpoint de privacidad.

Solución

Buscá el endpoint relacionado con GDPR/privacidad de datos en el código JS. Permite leer o solicitar borrado de datos de usuario. Manipulá el ID del usuario objetivo para acceder a datos ajenos.

8. Categoría: Broken Authentication**Autenticación Rota (OWASP A07)**

Fallas en la gestión de identidad y sesión: contraseñas débiles, JWT mal implementados, recuperación de contraseñas vulnerable, falta de MFA.

Password Strength

Objetivo: Registrarte con una contraseña extremadamente débil.

Solución

El formulario exige cierta complejidad, pero podés bypassarlo interceptando la petición con Burp y enviando una contraseña como 1 o a directamente al servidor, que no valida la política del lado del servidor.

Security Answer

Objetivo: Descubrir la respuesta de seguridad de un usuario.

Solución

La pregunta de seguridad suele tener una respuesta deducible u obtenible vía OSINT dentro de la app. Revisá perfiles, reviews o datos filtrados del usuario objetivo para inferir la respuesta (ej. nombre de mascota, ciudad natal).

Reset Jim's Password

Objetivo: Resetear la contraseña de Jim usando la pregunta de seguridad.

Solución

Usá la función «Olvidé mi contraseña» con el email de Jim. Respondé la pregunta de seguridad con la información que investigaste (OSINT en la app). Una vez correcta, establecé una nueva contraseña.

Reset Bender's Password

Objetivo: Resetear la contraseña de Bender.

Solución

Similar al anterior, pero la respuesta requiere investigar más a fondo la información de Bender (a menudo relacionada con referencias de la serie Futurama). Puede implicar encontrar datos ocultos en su perfil o en documentos filtrados.

Two Factor Authentication

Objetivo: Eludir o resolver el flujo de autenticación de dos factores.

Solución

Este desafío suele requerir interceptar el flujo de 2FA y manipular el token, o encontrar la semilla/secret para generar códigos válidos. Revisá cómo la app genera y valida el OTP; si el secret está expuesto, podés generar códigos válidos con una herramienta TOTP.

JWT Issues

Objetivo: Identificar y explotar fallas en la implementación de JWT.

Solución

1. Iniciá sesión y copió el token de la cookie `token` o la cabecera `Authorization`.
2. Pegalo en <https://jwt.io>.
3. Inspeccioná el **header** y el **payload**.
4. Intentá modificar el **email** en el payload por el de otro usuario.

JWT Unsigned (alg: none)

Objetivo: Forjar un token cambiando el algoritmo a **none**.

Solución

1. En jwt.io, cambiá el header: `.alg": "none"`.
2. Modificá el payload (ej. `email` a `admin@juice-sh.op`).
3. Borrá la firma (dejala vacía).
4. Usá este token para autenticarte. Si el servidor acepta **none**, quedás como admin.

Forged Signed JWT

Objetivo: Forjar un JWT firmado válido.

Solución

Requerís encontrar la **clave secreta** usada para firmar. Suele estar hardcodeda en el código fuente o filtrada en algún archivo. Una vez hallada, firmás el token modificado con esa clave (por ejemplo, con la librería `jsonwebtoken` de Node o jwt.io).

Login Support Team

Objetivo: Acceder como el equipo de soporte.

Solución

Combiná OSINT para descubrir el email del equipo de soporte y explotá una falla de autenticación (SQLi, pregunta de seguridad débil o JWT) para ingresar.

Login CISO

Objetivo: Iniciar sesión como el CISO.

Solución

El CISO es un usuario de alto nivel. Usualmente se accede investigando su email y aplicando las mismas técnicas de autenticación (reset de contraseña vía pregunta de seguridad, o JWT forjado).

Login MC SafeSearch

Objetivo: Iniciar sesión como MC SafeSearch.

Solución

MC SafeSearch es un personaje oculto. Su contraseña es una referencia cultural (a menudo ligada a una canción o meme). Buscá pistas en el código fuente, documentos ocultos o el archivo de letra asociado. También podés intentar fuerza bruta con un diccionario temático.

9. Categoría: Sensitive Data Exposure**Exposición de Datos Sensibles (OWASP A02)**

Datos protegidos expuestos por falta de cifrado, archivos de respaldo accesibles, logs públicos, o respuestas de API que filtran información.

Exposed Metrics

Objetivo: Acceder a métricas internas expuestas.

Solución

Buscá el endpoint de métricas, comúnmente `/metrics` o `/api/Metrics`. Suele exponer datos operativos del servidor (memoria, usuarios, contadores).

```
1 http://localhost:3000/metrics
```

Easter Egg

Objetivo: Encontrar el huevo de pascua oculto.

Solución

Buscá en el código JS una referencia a un archivo o ruta especial (a menudo `easter.egg`). Podés encontrarlo inspeccionando las rutas de la app o accediendo a un directorio oculto.

Leaked Unsafe Product

Objetivo: Descubrir un producto «inseguro» oculto en el catálogo.

Solución

Consultá la API de productos directamente:

```
1 http://localhost:3000/api/Products
```

Buscá entre los resultados un producto que no aparece en la UI pero sí en la respuesta de la API (suele tener un nombre o descripción llamativa).

Leaked Access Logs

Objetivo: Acceder a los logs de acceso del servidor.

Solución

Buscá archivos de log expuestos (ej. `access.log`) en directorios como `/ftp` o rutas estáticas. Los logs suelen revelar IPs, usuarios y peticiones, incluyendo credenciales en texto plano.

Access Log

Objetivo: Leer el registro de accesos.

Solución

Similar al anterior; accedé al archivo de log mediante una ruta directa o vía un *Local File Read*. La información puede usarse para descubrir otros usuarios o rutas.

Missing Encoding

Objetivo: Explotar la falta de codificación de caracteres.

Solución

Encontrá un input que no codifica correctamente caracteres especiales. Inyectá caracteres que rompan el formato (comillas, saltos de línea, HTML) para demostrar la falla (por ejemplo, alterando la estructura de un documento o respuesta).

Forgotten Sales Backup

Objetivo: Encontrar un archivo de respaldo olvidado.

Solución

Buscá archivos de backup (extensiones `.bak`, `.old`, `.zip`) en directorios web o en `/ftp`. Suelen contener datos de ventas o configuración sensible.

Cross-Site Imaging

Objetivo: Extraer información mediante imágenes referenciadas entre sitios.

Solución

Este desafío avanzado combina técnicas para «leer» datos a través de imágenes que cambian según el estado del servidor. Implica analizar cómo la app genera imágenes dinámicas y usarlas para exfiltrar información.

10. Categoría: XXE (XML External Entities)**XXE (OWASP A05)**

Cuando una aplicación procesa XML sin deshabilitar las entidades externas, un atacante puede incluir entidades que lean archivos locales o realizan peticiones SSRF.

XXE Data Exfiltration

Objetivo: Leer un archivo del servidor vía XXE.

Solución

En la función de subida de archivos (o donde se procese XML), subí un archivo con este contenido:

```
1 <?xml version="1.0" encoding="UTF-8"?>
2 <!DOCTYPE foo [
3   <!ENTITY xxe SYSTEM "file:///etc/passwd">
4 ]>
5 <foo>&xxe;</foo>
```

El servidor incluirá el contenido de `/etc/passwd` en la respuesta.

XXE DoS

Objetivo: Provocar denegación de servicio con XXE.

Solución

No envíes una bomba XML a una instancia de uso compartido. Documentá el riesgo revisando si el parser permite entidades externas o expansiones recursivas, comprobá que la configuración las rechaza y registrá el límite de tamaño o tiempo aplicado. Una demostración controlada requiere una copia descartable, límites estrictos y autorización docente.

11. Categoría: Security Misconfiguration

Configuración Errónea (OWASP A05)

Sistemas mal configurados: cabeceras de seguridad ausentes, CORS permisivo, manejo de errores que revela información, interfaces obsoletas activas.

Error Handling

Objetivo: Provocar un error que revele información.

Solución

Forzá un error en la aplicación, por ejemplo solicitando un recurso inexistente o un ID inválido en la API:

```
1 http://localhost:3000/api/Products/99999
```

La respuesta de error suele revelar detalles internos (stack trace, versión del framework).

Missing Security Headers

Objetivo: Identificar cabeceras de seguridad faltantes.

Solución

Inspectá las cabeceras de respuesta con Burp o las DevTools. Verificá la ausencia de cabeceras como:

- Content-Security-Policy
- X-Content-Type-Options
- X-Frame-Options
- Strict-Transport-Security

Documentá cuáles faltan y su impacto.

CORS Misconfiguration

Objetivo: Explotar una política CORS permisiva.

Solución

Envía una petición con la cabecera `Origin` de un dominio arbitrario y observá si la respuesta incluye `Access-Control-Allow-Origin` reflejando ese dominio. Si lo hace, la configuración CORS es insegura y permite peticiones cruzadas no autorizadas.

```
1 curl -H "Origin: http://evil.com" -I http://localhost:3000/api/Users/
```

12. Categoría: Business Logic

Lógica de Negocio

Fallas en el flujo de negocio que permiten acciones no previstas: cupones con descuento excesivo, comprar sin pagar, manipular pedidos.

Forged Coupon



Objetivo: Usar un cupón con descuento $\geq 80\%$.

Solución

Los cupones válidos siguen un patrón basado en el mes/año actual. El desafío requiere forjar un cupón con descuento mayor al permitido (80 %+).

1. Interceptá la aplicación del cupón en el checkout.
2. Analizá el formato de los cupones válidos (suelen ser del tipo MES+descuento).
3. Generá un cupón con descuento 80 o superior y aplicalo.

Coupon Issue



Objetivo: Resolver una inconsistencia en el sistema de cupones.

Solución

Aplicá un cupón y observá el comportamiento. El desafío suele consistir en encontrar cómo un cupón puede reutilizarse o aplicarse incorrectamente, documentando la falla de lógica.

Christmas Special



Objetivo: Comprar un producto especial de temporada.

Solución

Hay un producto navideño que normalmente no está disponible o requiere condiciones especiales. Buscá en la API el producto y forzalo al carrito, o encontrá la ruta oculta que lo vende.

Payback Time



Objetivo: Explotar el flujo de pago/devolución.

Solución

Manipulá el proceso de pago o reembolso para obtener un resultado inconsistente (por ejemplo, un reembolso mayor al pago, o pagar con saldo negativo). Interceptá las peticiones del checkout.

13. Categoría: Improper Input Validation

Upload Size



Objetivo: Subir un archivo que exceda el tamaño permitido.

Solución

La validación de tamaño es solo del lado del cliente. Interceptá la subida con Burp y reemplazá el archivo por uno más grande, o modificá el tamaño declarado en la petición.

Upload Type



Objetivo: Subir un tipo de archivo no permitido.

Solución

La restricción de extensión es del lado del cliente. Cambiá la extensión en la petición interceptada (ej. subir un `.exe` o `.php` aunque la UI solo permita imágenes). También podés usar doble extensión: `archivo.jpg.php`.

Extra Language



Objetivo: Agregar o acceder a un idioma no oficial.

Solución

Manipulá el parámetro de idioma en la petición o la cookie para establecer un idioma que no está en el selector de la UI, forzando un valor no listado.

14. Categoría: Insecure Deserialization

Blocked RCE



Objetivo: Ejecutar código remotamente a través de deserialización.

Solución

Este desafío avanzado requiere encontrar un endpoint que deserializa datos sin validar y enviar un objeto malicioso. Juice Shop bloquea los payloads RCE conocidos, por lo que debés encontrar una variante que bypass las protecciones.

Blocked RCE DoS



Objetivo: Provocar DoS mediante deserialización.

Solución

Similar al anterior, pero el objetivo es causar denegación de servicio en lugar de ejecución de código. Envía un payload de deserialización que consuma recursos excesivos.

15. Categoría: Cryptographic Issues**Weird Crypto**

Objetivo: Identificar el uso de un algoritmo criptográfico inusual o inseguro.

Solución

Revisá el código fuente de la app (o las respuestas de la API) en busca de algoritmos no estándar o débiles. Documentá cuál es y por qué es inseguro.

16. Categoría: Documentation / Awareness**Privacy Policy**

Objetivo: Leer la política de privacidad.

Solución

Navegá a la sección de política de privacidad de la tienda y leela (o simular su aceptación). Este desafío es de concientización.

17. Metodología de Trabajo Recomendada**Flujo de resolución**

1. **Explorá** la app como usuario normal (regístrate, comprá, navegá).
2. **Abrí Burp Suite** y activá el proxy con FoxyProxy.
3. **Revisá el código JS** del cliente (F12 → Sources) buscando rutas, endpoints y secretos.
4. **Inspectá la API REST**: la mayoría de los desafíos pasan por `/api/` o `/rest/`.
5. **Manipulá** las peticiones con Burp Repeater.
6. **Documentá** cada hallazgo con capturas.

17.1. Checklist del Hacker Web

- ¿Revisé `robots.txt` y `sitemap.xml`?
- ¿Busqué directorios ocultos (`/ftp`, `/api-docs`)?
- ¿Inspecté las cookies y tokens (JWT)?

- ¿Probé SQLi en todos los campos de entrada?
- ¿Manipulé los IDs en las peticiones de la API (IDOR)?
- ¿Revisé las cabeceras de seguridad?
- ¿Busqué archivos de respaldo (.bak, .old, .zip)?
- ¿Probé XSS en búsquedas, reviews y feedback?

18. Cheatsheet de Comandos Útiles

```
1 # Escaneo rapido de la app
2 nmap -sV -p 3000 localhost
3
4 # Buscar rutas y archivos comunes
5 gobuster dir -u http://localhost:3000 -w common.txt
6
7 # Escaneo web
8 nikto -h http://localhost:3000
9
10 # Consultar la API de productos
11 curl http://localhost:3000/api/Products
12
13 # Ver cabeceras de respuesta
14 curl -I http://localhost:3000
15
16 # Enviar una peticion con Origin custom (CORS)
17 curl -H "Origin: http://evil.com" -I http://localhost:3000/api/Users/
```

19. Fuentes y bibliografía

19.1. Documentación oficial y libro de soluciones

- OWASP Foundation. *OWASP Juice Shop*: <https://owasp.org/www-project-juice-shop/>
- Kimminich, B. *Pwning OWASP Juice Shop Companion Guide*: <https://pwning.owasp-juice-shop/>
- OWASP Foundation. *OWASP Top 10:2021*: <https://owasp.org/www-project-top-ten/>
- Repositorio oficial: <https://github.com/juice-shop/juice-shop>

19.2. Bibliografía de la cátedra

- Chicano Tejada, E. (2023). *Auditoría de seguridad informática. IFCT0109* (2.^a ed.). IC Editorial — eLibro.
- Evans, L. (2019). *Ethical Hacking: The Ultimate Guide to Using Penetration Testing to Audit and Improve the Cybersecurity of Computer Networks for Beginners*. Amazon Digital Services LLC — KDP.
- White, A. & Clark, B. (2017). *BTFM: Blue Team Field Manual*. CreateSpace.

19.3. Herramientas

- PortSwigger. *Burp Suite*: <https://portswigger.net/burp>
- JWT.io: <https://jwt.io/>
- OWASP ZAP: <https://www.zaproxy.org/>